The AI security stack

An AI system asks, decides, acts and reads data. Each SC-500 control sits on one of those steps. Know the layer and you know the answer.

SC-500 Academy posters
Front: where each control acts
Checked against Microsoft Learn on 20 October 2026

Where each control acts

Read top to bottom: a request starts with someone asking and ends at the data. Every SC-500 security-for-AI bullet sits on one layer.

Who asks
people and agents

A person in Microsoft 365 Copilot
Copilot answers with the signed-in user's own permissions, through Microsoft Graph. No privileged index.

Copilot Studio agent
Built by any licensed maker. Generative orchestration plans which tool to call next.

Foundry agent or app
Calls a model deployment, and for agents, tools such as search, functions and APIs.

Inventory
what agents exist

Agent management in the Microsoft 365 admin center 3.1.11
Agents, All agents: the tenant registry. Block, delete (30-day restore), assign a new owner, approve store submissions.

Data and AI security dashboard 3.1.10
Defender for Cloud: AI resources found, prompts scanned, alerts, internet-exposed grounding sources. Full view needs Defender CSPM plus the protection plans.

Identity
who the agent is

Conditional Access for Agent ID 3.1.4
Target the token subject: the user for on-behalf-of agents, agent identities or blueprints for autonomous ones, the agent user (preview) for agents with accounts. All users skips agent users.

Agent ID access 3.1.6
Owners and sponsors, access packages that expire, sponsorship lifecycle workflows. Access decays unless someone renews it.

Blast radius in Defender XDR 3.1.5
If the agent were subverted, what could it reach? Its permissions, tools, grounding sources, and for on-behalf-of agents, the user's.

Runtime
what it is allowed to do now

Copilot Studio real-time protection (preview) 3.1.3
Defender checks each tool call before it runs. In the new rules experience the Default rule only audits; a custom rule blocks. Generative orchestration only.

AI gateway in API Management 3.1.7
One chokepoint in front of models: token limits per consumer, content safety, the model key kept off the apps.

Foundry guardrails 3.1.9
Controls on user input, output, and for agents (preview) tool calls and tool responses. Annotate, or annotate and block.

Data
what it can read

SharePoint oversharing 3.1.1
Data access governance reports find it. Restricted Content Discovery hides a site from Copilot; Restricted Access Control removes access.

Purview DSPM (was DSPM for AI) 3.1.2
Who used which AI app with what data. Labels with encryption: Copilot needs VIEW and EXTRACT to summarise.

Detection
who notices

Defender for AI Services 3.1.8
Runtime threat detection on prompts and responses: jailbreaks, data leakage, credential theft. Alerts; never blocks.

Defender CSPM 3.1.10
Discovers AI resources, builds the AI bill of materials, finds AI attack paths. Posture, not runtime alerts.

One indirect prompt injection, five places to stop it

An attacker never touches the agent. They plant instructions in content it will read, and let its own access do the rest.

Instructions planted in a document 3.1.1 3.1.2
A file the agent grounds on contains hidden instructions, often in a site shared far too widely.
Stop it: Fix the oversharing; RCD or RAC while you review; labels without EXTRACT.

The agent reads it 3.1.9
Grounding or a tool returns the poisoned text into the agent's context.
Stop it: A guardrail with indirect attack detection on the tool response.

The agent plans an action 3.1.3 3.1.9
It decides to send an email or call an API with data it holds.
Stop it: A real-time protection custom rule blocks the tool call; a tool call control in Foundry.

The action runs with the agent's access 3.1.4 3.1.6
Whatever the agent identity, or the delegated user, can reach is in play.
Stop it: Least privilege, expiring access, Conditional Access for unapproved agents.

Someone notices 3.1.5 3.1.8
The SOC needs the alert, the prompt and the reach.
Stop it: Defender alerts with prompt evidence; blast radius; DSPM activity.

Licence gates

3.1.1 3.1.4 3.1.8

Capability	Needs
Snapshot DAG reports, RCD, RAC	SharePoint Advanced Management. Unlocked automatically if anyone in the tenant has a Microsoft 365 Copilot licence
DAG activity reports	Microsoft 365 E5, up to 10,000 sites, after enabling data collection
Conditional Access for agents	Microsoft 365 E7, or Agent 365 with at least Entra ID P1 or Microsoft 365 E3
Generative Copilot Studio agents	Microsoft 365 Copilot, a Copilot Studio licence or pay-as-you-go. E5 alone has only the Teams plan
Agent inventory and basic actions	Microsoft 365 plans. Policy templates and tool control need E7 or Agent 365
Defender for AI Services	The plan, per subscription. 30-day trial capped by tokens scanned
Data security for AI interactions	Purview pay-as-you-go meters or Agent 365; enable it in Foundry
llm-token-limit	Any API Management tier except Consumption

Dates that changed the answers

3.1.3 3.1.8

When	What changed
1 July 2026	Foundry agent threat protection, discovery and posture move to Microsoft Agent 365, and Foundry agent data leaves the Data and AI security dashboard. Defender for AI Services keeps protecting Foundry Models.
1 July 2026	Copilot Studio threat detection alerts move to Agent 365 observability. Microsoft's pages disagree on whether real-time protection continues without an Agent 365 licence: **needs verification**.
31 July 2026	New enablement of Restricted SharePoint Search blocked. Plan around Restricted Content Discovery.

Check Microsoft Learn before answering any question that depends on these.

Words you must not mix up

Term	Means
Agent identity blueprint	The template agent identities are created from. Cannot act on resources
Agent identity	The principal that does the work
Agent user	A user-shaped account linked to one agent identity
Sponsor	The accountable human for an agent
Prompt Shields	Attack detection: jailbreaks (user prompt attacks) and indirect attacks
Harm categories	Content rules: hate, sexual, violence, self-harm
Generative orchestration	The agent plans its own tool calls. The only Copilot Studio kind real-time protection checks

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.

The AI security stack

The details SC-500 questions turn on: what each control checks, where it is switched on, and what it leaves alone.

SC-500 Academy posters
Back: how each control behaves
Checked against Microsoft Learn on 20 October 2026

AI gateway policies 3.1.7

Policy	Does	Returns
`llm-token-limit`	Tokens per minute and quotas, per counter key (subscription, IP or expression)	429 rate, 403 quota
`estimate-prompt-tokens`, an attribute of llm-token-limit	Estimates prompt tokens before forwarding, which can reduce over-limit calls reaching the model	
`llm-content-safety`	Sends prompts or completions to Azure AI Content Safety. `shield-prompt` is off by default	403 when blocked
`llm-semantic-cache-*`	Returns cached completions for similar prompts. Partition with `vary-by` or callers see each other's answers	
`authentication-managed-identity`	The gateway calls the model as itself; apps never hold the key	

- In Foundry: **Manage, AI Gateway**, at Foundry resource level. New projects join automatically; existing projects must be added.
- **The counter key decides fairness.** A constant key makes every consumer share one bucket.

Copilot Studio real-time protection (preview) 3.1.3

Agent plans a tool call → **Defender evaluates** within about 1 s → **Audit or block** the rule decides

- **Two sides, both required.** Defender portal: Settings, Security for AI, Get started, Copilot Studio step, real-time protection on. Power Platform admin center: Security, Threat detection, per environment.
- **New rules experience (Agent 365):** the built-in Default rule audits every agent; to block, create a custom rule under Settings, Security for AI, Policies & rules, Real-time protection. The legacy Defender for Cloud Apps path stays unchanged for tenants that keep it.
- Only **generative orchestration** agents. Classic agents are skipped.
- No answer in time: the default is **allow**; you can change it to block.
- Blocks are recorded as behaviours. When a blocking rule covers an agent, near-real-time alerts are not generated.
- Evidence it works: the Copilot Studio step shows **Connected**.

Foundry guardrails 3.1.9

Intervention point	Models	Agents (preview)
User input	**Yes**	**Yes**
Tool call	No	**Yes**, tools that support it
Tool response	No	**Yes**, tools that support it
Output	**Yes**	**Yes**

- A guardrail is a set of controls: **risk** + **intervention point** + **action** (annotate, or annotate and block; agents only annotate and block).
- **An agent's own guardrail replaces the model's entirely.** No agent guardrail: it inherits the model deployment's.
- Default `Microsoft.DefaultV2` cannot be edited. Azure OpenAI default: harm categories at Medium, jailbreak on prompts, protected material on completions. **No indirect attack detection by default.**
- Groundedness and Spotlighting apply to models only. Blocklists: up to 10,000 terms, Azure OpenAI only.

Conditional Access for agents 3.1.4

Agent pattern	Token subject	Target
On-behalf-of	The signed-in user	Users and groups
Autonomous	The agent identity	Agent identities or blueprints
Agent user	The agent's user account	That user account (preview)

- A policy on one subject does not cover the others.
- Agents cannot answer MFA. For agent identities the grant control is **Block**, with conditions such as **agent risk** (preview).
- Agent users on an Intune-managed Windows 365 Cloud PC for Agents can also be held to a **compliant device** or **compliant network** (preview).
- Licence: Microsoft 365 E7, or Agent 365 with Entra ID P1 or Microsoft 365 E3. Agent risk conditions also need ID Protection: Entra ID P2 or E5.
- Not evaluated for blueprint token requests that create agents, with security defaults, or when an API key is used instead of an Entra token.

Agent ID access and the agent registry 3.1.5 3.1.6 3.1.11

- **owner**: blueprint and agent identity. **sponsor**: blueprint, agent identity, agent user. **manager**: agent user.
- Access packages give agents access that **expires** unless the sponsor asks to extend it.
- Sponsorship lifecycle workflows move sponsorship when a sponsor leaves.
- Microsoft 365 admin center, Agents, All agents: install, block, delete and restore (30 days), assign a new owner, start or stop a Foundry agent.
- Blast radius: Defender incident graph, **View blast radius**. Needs Exposure Management read and Sentinel data lake onboarding before 23 September 2026 (legacy incident experience); it only reaches assets classified as critical.

Oversharing and DSPM for AI 3.1.1 3.1.2

Control	Changes access?
Restricted Content Discovery	No. Hides the site from Copilot and org-wide search
Restricted Access Control	Yes. Only the named groups can open the site
Label with encryption, no EXTRACT	No. The user opens it; Copilot cannot summarise it
DLP for Microsoft 365 Copilot	Stops Copilot processing labelled content

- Microsoft 365 Copilot prompts and responses live in the user's mailbox: **eDiscovery** or the AI interaction event in activity explorer.
- Copilot in Fabric, Security Copilot and third-party apps need a **collection policy**, with content capture where needed.
- DSPM for AI is now **DSPM for AI (classic)**. The new **DSPM** (Purview portal, Solutions, DSPM) replaces it and adds AI observability for apps and agents.
- Reports need at least a day to fill. RCD can take more than a week on very large sites.

SharePoint controls that shrink what Copilot can find 3.1.1

- Default sharing links set to **Specific people**, not the whole organisation.
- Hide the **Everyone except external users** claim from the sharing picker.
- Restrict member sharing on sensitive sites, so owners handle access requests.
- **Site access reviews** from a data access governance report: the site owner decides what was oversharing.
- **Inactive site policies**: every abandoned site is more content Copilot reasons over.
- Hiding is not fixing: RCD buys time, permissions are the fix.

Defender for AI Services 3.1.8 3.1.10

Component	Adds	Status
Suspicious prompt evidence	Redacted prompt snippets in each alert	GA
Data security for AI interactions	Foundry app and agent interactions go to Purview	Now set in Foundry
AI model security	Scans models in Azure Machine Learning	Preview

- Enable per subscription: Environment settings, Defender plans, **AI services**. Owner or Contributor.
- Without prompt evidence, alerts still fire but **the prompt is masked**.
- Enforce everywhere with the built-in DeployIfNotExists policy *Enable threat protection for AI workloads*. *Configure Microsoft Defender threat protection for AI Services* keeps new plan capabilities switched on as they are added.

Pick the layer from the requirement

"nobody outside the team should find it through Copilot"	→ **Restricted Content Discovery**
"unauthorised users must lose access"	→ **Restricted Access Control**
"what did users type into AI apps"	→ **Purview DSPM, eDiscovery, collection policies**
"block the risky tool call before it runs"	→ **Real-time protection, custom blocking rule**
"no agent may sign in unless approved"	→ **Conditional Access for agent identities**
"access must expire if nobody renews it"	→ **Access package for the agent identity**
"one app must not use everyone's tokens"	→ **AI gateway token limit**
"scan what a tool returns"	→ **Agent guardrail, tool response control**
"tell the SOC about jailbreak attempts"	→ **Defender for AI Services**
"which AI resources do we even have"	→ **Defender CSPM, Data and AI security dashboard**
"find and block shadow agents"	→ **Microsoft 365 admin center agents**
"what could this agent reach if subverted"	→ **Blast radius in Defender XDR**

Ids such as 2.3.6 are positions in the official skills outline, assigned by the Academy. Microsoft does not number them.

CC BY 4.0. Not affiliated with Microsoft. Defaults, portals and licences change: confirm on Microsoft Learn.